

Security Incident Report

CLOUDORA SECURITY OPERATIONS | CLD-IR-0001

Field	Detail
Report ID	CLD-IR-0001
Related ticket	CLD-0001 - Suspicious login on daniel.reeve@cloudora.io
Report title	Investigation into Account Takeover, MFA Tampering, and Email Rule Setup
Analyst	SOC Analyst
Date of report (UTC)	2026-08-10
Incident severity	P1 - CEO account breached before a major client deal; an inbox rule was planted.
Status	Contained - attacker kicked out and additional accounts checked.
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Over three nights, an attacker tested common passwords against 26 company accounts using IP addresses from Nigeria. On the morning of August 10, they cracked the passwords for both the CEO (Daniel Reeve) and an employee (Priya Nair). On the CEO's account, the attacker added their own phone as an MFA method and set up a rule to hide invoice emails. The team spotted the login when Daniel signed in from London a few hours later. We ended all active sessions, changed passwords, deleted the attacker's MFA device and email rule, and blocked the IPs. No fraud or payment activity was identified in the supplied logs, and we flagged the other 24 accounts that were targeted so they can reset their passwords too.

2. Incident timeline

All times are in UTC. Data comes from CloudoraSignIn_CL and CloudoraAudit_CL.

Time (UTC)	Source	Event	Evidence / notes
Aug 08, 00:00-05:00	Sign-in	Night 1 password spray: 44 failures across ~20 accounts	50126 failures from 102.89.x.x addresses.
Aug 09, 00:00-05:00	Sign-in	Night 2 password spray: 36 failures	Same IPs, a few attempts per account.
Aug 10, 03:09:12	Sign-in	Failed CEO login	50126 from 102.89.44.17.
Aug 10, 03:10:41	Sign-in	Failed CEO login	50126 from 102.89.44.17.
Aug 10, 03:12:05	Sign-in	CEO account compromised	Success from 102.89.44.17 on Windows 10 / Chrome.
Aug 10, 03:14:30	Sign-in	Outlook Web opened	Mailbox opened from 102.89.44.17.
Aug 10, 03:18:44	Audit	MFA device added	Pixel 6 registered on CEO account.
Aug 10, 03:26:02	Sign-in	Azure Portal opened	Session from 102.89.44.17.
Aug 10, 03:31:09	Audit	Inbox rule created	RSS Subscriptions hides invoice and finance emails.
Aug 10, 03:44:55	Sign-in	Failed Priya login	50126 from 102.89.45.101.
Aug 10, 03:47:18	Sign-in	Priya account compromised	Success from 102.89.45.101.
Aug 10, 03:52:40	Sign-in	SharePoint Online accessed	Used Priya's account from 102.89.45.101.
Aug 10, 08:41:00	Sign-in	Daniel signs in from London	Regular Mac/Safari from 203.0.113.11.
Aug 10, 08:55:00	Ticket	Alert raised by IT admin	CLD-0001 opened for impossible travel.

3. Findings

Finding 1: The CEO's account had an unauthorized login, not normal travel

Fact: Daniel Reeve's account was logged into by someone else from Lagos, Nigeria.

Evidence: The account logged in at 03:12 UTC from 102.89.44.17 using Windows 10 and Chrome. Daniel normally signs in from London on a Mac using Safari, and he signed in from London as usual at 08:41 UTC.

Why it matters: Flying between Lagos and London in under six hours is not possible. Two wrong password tries immediately before the login support an attacker password attempt, not a VPN or travel glitch.

Finding 2: Entry was gained through a slow password spray

Fact: The available sign-in evidence supports a slow password-spray attack against many users over three days.

Evidence: Three Lagos IPs made 114 failed attempts across 26 accounts between midnight and 5 AM. Each account was tried only 1 to 3 times per night.

Why it matters: Spreading attempts out avoids locking accounts, so nobody notices until a password works.

Finding 3: The attacker added their own MFA device to keep access

Fact: The attacker linked their own phone to Daniel's account.

Evidence: At 03:18 UTC, audit logs show a new security method added from 102.89.44.17: Pixel 6.

Why it matters: A password reset alone would leave the attacker able to approve MFA prompts.

Finding 4: An inbox rule was set up to steal and hide financial emails

Fact: The attacker tampered with Daniel's mailbox settings.

Evidence: RSS Subscriptions moves mail containing invoice or sent by finance@cloudora.io to RSS Feeds and marks it read.

Why it matters: This hides billing and invoice emails so the attacker can impersonate Daniel and commit payment fraud.

Finding 5: Priya Nair's account was also breached

Fact: Daniel was not the only victim.

Evidence: The same IP pool got into priya.nair@cloudora.io at 03:47 UTC and opened SharePoint five minutes later.

Why it matters: Another staff member was breached and had internal files opened. No attacker persistence was observed for Priya in the available audit logs; this is not proof that the account was clean, so the same containment steps are still required.

Finding 6: Omar Farah's logins were legitimate travel

Fact: Omar's logins from Dubai were genuine.

Evidence: Omar had 12 Dubai logins across August 8 to 10, during daytime hours, with zero password errors and his regular iPhone.

Why it matters: This distinguishes real travel from a hack. Omar still needs a reset because he was targeted by the spray.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IPv4	102.89.44.17	Aug 08, 00:00	Spray, CEO login, MFA setup, and mail rule.
IPv4	102.89.44.23	Aug 08, 00:00	Password-spray source.
IPv4	102.89.45.101	Aug 08, 00:00	Spray and Priya Nair breach.
User Agent / OS	Windows 10 / Chrome 125	Aug 08	Attacker device fingerprint.
MFA Device	Pixel 6	Aug 10, 03:18:44	Rogue phone on Daniel's account.
Mailbox Rule	RSS Subscriptions	Aug 10, 03:31:09	Rule created to hide invoice emails.

5. MITRE ATT&CK mapping

Tactic	Technique ID	Technique name	Evidenced by
Credential Access	T1110.003	Brute Force: Password Spraying	Finding 2: 114 failures across 26 users.
Initial Access	T1078	Valid Accounts	Findings 1 and 5: successful logins.
Persistence	T1098.005	Account Manipulation: Device Registration	Finding 3: Pixel 6 registered for MFA.
Defense Evasion	T1564.008	Hide Artifacts: Email Hiding Rules	Finding 4: RSS Subscriptions inbox rule.

6. Scope

Accounts confirmed compromised (2): daniel.reeve@cloudora.io and priya.nair@cloudora.io. Both had successful logins from attacker IPs on August 10.

Accounts targeted but not breached (24): alba.vega, amelia.frost, aria.reid, cole.burke, dina.said, emma.hayes, ethan.wells, freya.lynn, gwen.muir, isla.grant, joel.kerr, jude.ross, kian.patel, leah.stone, lena.voss, liam.doyle, mira.shah, nina.cole, omar.farah, rhys.owen, ruth.dean, ryan.boyd, seth.lane, and sofia.marino (all @cloudora.io).

Accounts investigated and cleared (1): omar.farah@cloudora.io. His Dubai activity was confirmed as benign business travel, though he remains in the reset list because the spray targeted him.

7. Actions taken

Carried out on August 10, 2026:

Time	Action	Performed by	Verified how
10:15	Revoked sessions and tokens for Daniel and Priya	SOC Analyst	Confirmed open sessions dropped in Entra ID.
10:20	Reset passwords for both accounts	SOC Analyst	Required at next sign-in.
10:25	Removed Pixel 6 MFA device from Daniel's profile	SOC Analyst	Only Daniel's real device remained.
10:30	Deleted RSS Subscriptions inbox rule	SOC Analyst	Confirmed it was absent in Exchange.
10:35	Blocked the three attacker IPs in Conditional Access	SOC Analyst	IPs added to block list.
10:45	Re-checked sign-in and audit logs	SOC Analyst	No traffic from attacker IPs after containment.

8. Recommendations

- Reset all 24 targeted accounts immediately.
- Warn the billing team to verify bank-detail changes by phone.
- Require MFA on every account and disable legacy protocols that can bypass it.
- Alert when an executive adds MFA or creates a rule that moves invoice emails.
- Deploy a SIEM rule to detect an IP failing passwords across several users.

9. Lessons learned

Catching sprays early: The attack was discovered 5.5 hours after the CEO's account fell because an IT admin saw Daniel login from two distant places. A spray detection rule could have blocked the attacker on night one.

Checking audit logs matters: A password reset alone would have left the Pixel 6 phone and hiding email rule active. Reviewing audit logs is essential to clean up an account completely.

Context over simple alerts: Omar's Dubai sign-ins looked suspicious, but his device and daytime pattern showed legitimate travel, preventing a false alarm.